

ACME Corp: Cloud Security Standards v2.0

Generated by Gemini 2.0 Flash

```text

**\*\*ACME Corporation - Internal Memo\*\***

**\*\*Subject: Cloud Security Standards\*\***

**\*\*Date: October 26, 2023\*\***

**\*\*From: Chief Information Security Officer (CISO)\*\***

**\*\*To: All ACME Corp. Employees & Contractors Utilizing Cloud Resources\*\***

**\*\*1.0 Introduction\*\***

This document outlines the mandatory Cloud Security Standards for all ACME Corporation employees and contractors utilizing cloud resources, primarily within [Specify Cloud Provider, e.g., AWS, Azure, GCP]. These standards are designed to protect ACME Corporation's data and infrastructure, maintain compliance with relevant regulations, and minimize the risk of security breaches. Compliance is mandatory for all cloud deployments and activities. Failure to adhere to these standards may result in disciplinary action and/or revocation of cloud access privileges. These standards will be reviewed and updated periodically. All users are responsible for staying informed of the latest version.

**\*\*2.0 Compute (EC2 Instances)\*\***

2.1 **\*\*Secure Access:\*\*** Access to EC2 instances must be strictly controlled.

2.1.1 **\*\*Port 22 Restriction:\*\*** Public access to port 22 (SSH) is strictly prohibited. All SSH access to EC2 instances must be conducted via a secure bastion host or a VPN connection using secure cryptographic protocols (e.g., TLS 1.2 or higher). Direct internet access to port 22 on EC2 instances is a significant security risk and is not permitted.

2.1.2 **\*\*Security Groups:\*\*** Security groups must be configured with the principle of least privilege, allowing only necessary traffic to and from EC2 instances. Overly permissive security group configurations are prohibited.

2.2 **\*\*Instance Hardening:\*\*** EC2 instances must be hardened according to ACME Corporation's baseline hardening standards, which include regularly applying security patches, disabling unnecessary services, and implementing host-based intrusion detection systems (HIDS).

**\*\*3.0 Storage (S3 Buckets)\*\***

## **3.1 \*\*Versioning:\*\***

3.1.1 **\*\*Versioning Enabled:\*\*** All production S3 buckets must have Versioning Enabled to prevent data loss due to accidental deletion or overwriting of objects. Versioning provides a mechanism to recover previous versions of objects.

## **3.2 \*\*Encryption:\*\***

3.2.1 **Server-Side Encryption Mandatory:** Server-Side Encryption (SSE-S3 or KMS) is mandatory for all objects stored in S3 buckets. This ensures that data is encrypted at rest, protecting it from unauthorized access. KMS encryption is preferred for enhanced key management and control.

## **3.3 \*\*Access Control:\*\***

3.3.1 **Least Privilege:** S3 bucket policies must be configured using the principle of least privilege, granting only the necessary permissions to users and applications that require access to the data. Publicly accessible S3 buckets are strictly prohibited unless explicitly approved by the CISO.

3.3.2 **Access Logging:** S3 bucket access logging must be enabled to provide an audit trail of all requests made to the bucket. These logs should be securely stored and regularly reviewed for suspicious activity.

**4.0 Databases (RDS Instances)**

## **4.1 \*\*Private Access:\*\***

4.1.1 **No Public Access:** RDS database instances must not be publicly accessible. They should reside in private subnets within a Virtual Private Cloud (VPC) and be accessible only from within the ACME Corporation network or via a secure VPN connection.

## **4.2 \*\*Encryption:\*\***

4.2.1 **Encryption at Rest and in Transit:** RDS database instances must be configured with encryption at rest using KMS. Encryption in transit must also be enabled to protect data while it is being transmitted to and from the database.

## **4.3 \*\*Backup and Recovery:\*\***

4.3.1 **Automated Backups:** Automated backups must be enabled for all RDS database instances to ensure that data can be recovered in the event of a failure. Backup retention periods should be defined based on the criticality of the data.

**5.0 Identity and Access Management (IAM)**

## **5.1 \*\*Multi-Factor Authentication (MFA):\*\***

5.1.1 **MFA Required:** MFA is required for all human users with console access to [Specify Cloud Provider, e.g., AWS] resources. This adds an extra layer of security to protect against unauthorized access, even if a password is compromised.

5.2 **Principle of Least Privilege:** IAM roles and policies must be configured with the principle of least privilege, granting only the necessary permissions to perform specific tasks. Overly permissive IAM policies are prohibited.

5.3 **Regular Review:** IAM roles and policies should be regularly reviewed and updated to ensure that they remain appropriate and do not grant unnecessary permissions.

## **6.0 Logging and Monitoring**

6.1 **Centralized Logging:** All cloud resources should be configured to send logs to a centralized logging system for analysis and monitoring.

6.2 **Security Monitoring:** Security monitoring tools and techniques must be implemented to detect and respond to security incidents in a timely manner.

## **7.0 Compliance and Enforcement**

7.1 **Regular Audits:** Regular security audits will be conducted to ensure compliance with these Cloud Security Standards.

7.2 **Enforcement:** Failure to comply with these Cloud Security Standards may result in corrective actions, disciplinary action, and/or revocation of cloud access privileges.

## **8.0 Contact Information**

For questions or clarification regarding these Cloud Security Standards, please contact the Information Security Team at [Insert Email Address or Helpdesk Information].

---